CloudDesk Technologies

Vendor Risk Management Policy

1. Authority, purpose and scope

SYNTHETIC / DEMO - document control

CD-VRM-001 | Version 1.0 (wording revision). Proposed effective date: 2026-10-22. Planned next review: 2027-10-22. These dates are proposals, not an approved schedule. The Engineering Lead owns this policy. The CTO is accountable for adoption and material residual risk. Review annually and after material changes or incidents. Approval_status: not_recorded; review_status: requires_user_review.

Status and adoption limits

CloudDesk Technologies is a fictional 75-person B2B SaaS company. This proposed policy describes security requirements for CloudDesk Technologies. It is a fictional demonstration document and does not establish that any controls are operating. No actual vendors, completed assessments, certifications, SOC 2 reports, ISO certification, DPA or legal compliance are asserted. No implemented monitoring or audit evidence is supplied. Human content review and recorded CTO approval are required before adoption.

Purpose and supplier scope

This policy addresses confidentiality, integrity, availability and privacy risks from vendor selection through exit. It covers processors/subprocessors, SaaS and cloud vendors, contractors, outsourced support and critical dependencies. These include identity, KMS, DNS, storage and recovery services where applicable. Review trials, free services and integrations before enabling access or sharing information in scope. A low price or purchasing route does not remove security review.

Ownership and related authority

Assign a business owner and system owner to each vendor. Owners document its purpose, dependencies and risk, and coordinate contracts with qualified advice where needed. No staffed procurement, privacy or legal department is assumed. The Engineering Lead reviews assessments and tracks findings. The CTO accepts material residual risk. All seven related policies retain authority over identity, encryption, security governance, incidents, recovery, changes and personnel. Record conflicts for the Engineering Lead and CTO to resolve before adoption. Vendor approval grants no new authority to decrypt, destroy keys or communicate externally.

Vendor Risk Management Policy

2. Vendor inventory and risk tiering

Inventory and accountable ownership

Before onboarding, record a vendor ID, proposed legal entity and service, business owner, system owner, purpose, engagement dates and renewal/exit conditions. Map information classes, customer data categories, processing purposes, privileges and interfaces. Identify storage, processing and support locations, subprocessors and upstream dependencies. Track contract and assessment versions, risk tier and rationale, findings, approvals, review dates, exit plans and evidence limitations. Update the inventory after material changes and retirement. This sample supplies no actual vendor inventory.

Risk tiering dimensions

Assess customer data sensitivity and volume, processor/subprocessor roles, administrative or persistent access, service criticality, resilience and recoverability. Consider geography/jurisdiction, cross-border processing, concentration and substitutability. Identify shared cloud, identity, region and fourth-party failure paths. Record inherent risk, verified safeguards and residual risk separately. Missing information requires review; it is not evidence of low risk.

Proposed tiers and escalation

Classify vendors as high risk if they have privileged production access, process sensitive customer data, or provide a critical dependency whose failure could cause material harm. Flag vendors essential to service or recovery as critical, separately from their risk tier, to retain annual reassessment. Moderate risk means bounded nonprivileged access to nonpublic information without high-risk characteristics. Low risk requires documented limited exposure and low impact. The Engineering Lead reviews the rationale. Use the higher applicable tier when dimensions conflict, and escalate unresolved uncertainty to the CTO.

Reassessment and risk register

Reassess critical vendors annually and affected vendors after material changes or incidents. Triggers include new subprocessors, ownership, regions, data use, privileges, assurance gaps and resilience concerns. Owners track renewal conditions and arrange review before changed use. Under CD-ISP-001, the Engineering Lead coordinates security risk assessments at least annually and open-risk reviews quarterly. Record findings, remediation owners, due dates and CTO acceptance decisions. Escalate overdue material risks rather than renewing silently.

Vendor Risk Management Policy

3. Pre-onboarding due diligence and agreements

Security and privacy due diligence before use

Before onboarding or enabling access in scope, owners document data flows, minimization, purpose, access needs and shared responsibility. The Engineering Lead reviews security and privacy due diligence in proportion to risk. Cover identity controls, tenant isolation, encryption, vulnerabilities, incident handling, available logs, resilience, deletion, locations and subcontractors. Review privacy terms and processor/subprocessor obligations with qualified advice where applicable. Assess lawful processing and transfer needs case by case. A signed DPA alone does not establish legal compliance.

Appropriate evidence and assurance gaps

Request evidence in proportion to risk. This may include security questionnaires, architecture explanations and relevant policies. Request independent assessment summaries if available. Use scoped technical validation and recovery/deletion descriptions where relevant. Check dates, scope and service coverage. Review exclusions, provenance and remediation status. Record unavailable evidence and unverified claims. No vendor certification is assumed or universally required. A SOC 2 report or ISO certificate alone would not establish suitability. Restrict copies of confidential reports. Do not request plaintext secrets or unnecessary personal data.

Contract security and incident terms

Before use in scope, review contract terms for confidentiality, permitted data use, restrictions on secondary use, security responsibilities and approved access. Address incident cooperation and breach/incident reporting under applicable contracts and law. Specify triggers, recipients, timing basis and updates for the engagement; there is no universal notification deadline. Cover data return/deletion, retained backups and holds, subcontractor controls/change notice, assurance rights, service changes and exit assistance. Record unresolved terms and obtain appropriate advice. No executed contract is supplied.

Approval gate for high-risk use

The Engineering Lead reviews assessment scope, evidence limitations, safeguards and unresolved findings before high-risk use. CTO acceptance of material residual risk is required before use. Record the decision maker, date, scope, conditions, owner and reassessment triggers. Missing material evidence or unresolved unacceptable risk blocks planned onboarding or changed use until mitigated or explicitly accepted through authorized governance. Purchasing approval and vendor sales claims do not constitute security approval. Use bounded exceptions for planned deviations. Mark an assessment complete only when supporting review records exist.

Vendor Risk Management Policy

4. Integration, access and company-side safeguards

Onboarding identity and access

Follow approved onboarding under CD-HRS-001 and access control. Use unique user accounts and multi-factor authentication for administrative access. Before provisioning, document the sponsor, role, start/end dates, system-owner approval and least privilege. Review user access permissions every quarter, including vendor workforce, dormant identities and sponsor validity. Limit service identities and OAuth/API scopes to approved functions. Protect secrets and record grants. Follow personnel governance for training and confidentiality without assuming identical employee screening rules for vendor workers.

Encryption and shared responsibility

CloudDesk requirements remain TLS 1.2 or TLS 1.3 for transport in scope, AES-256 at rest for production storage and backups in scope, and managed KMS for production keys under CD-ENC-001. Assess vendor controls against the applicable data flows and requirements; do not blindly assign company KMS architecture or every company control to all vendors. Document cloud shared responsibility boundaries, evidence, gaps and required contract safeguards. Escalate deviations through encryption governance. Existing public marketing storage scope remains; protect administrative and authentication traffic.

Integration changes and key boundaries

Assess integrations, regions, subprocessors, data flows and permission changes before enabling changed access. Technical changes in scope follow CD-CHG-001, including testing, approval and rollback/recovery plans. The Engineering Lead approves key grants; key administrators have no default decrypt permission. Review grants quarterly and rotate symmetric key-encryption keys at least every 12 months. Restrict older versions needed for retained data, backups and holds. Key destruction requires Engineering Lead and CTO approval after retention and recovery checks. Vendor exit does not itself authorize key destruction.

Continuous monitoring proposals

Owners propose ongoing oversight in proportion to risk. Cover vendor advisories, service/security changes, incident notices, assurance expiry, unresolved findings, access changes and concentration indicators. Before adoption, define sources, review cadence, substitutes and escalation conditions. No existing monitoring tool, staffed service, continuous telemetry coverage or completed monitoring is asserted. Record observations and uncertainty using verified contacts. Monitoring supplements annual critical-vendor reassessment and reviews triggered by events; it does not prove absence of compromise.

Vendor Risk Management Policy

5. Incidents, resilience and fourth parties

Vendor incident escalation and notification

Promptly report suspected vendor exposure, unauthorized access or disruption to the Engineering Lead through verified internal routes to be established before adoption. Use the CTO or a designated alternate if the lead is unavailable. Under CD-IRP-001, link vendor notices and affected services to an incident record, preserve evidence and reassess severity as facts change. Responders may take urgent reversible containment action without waiting for routine approvals. The CTO authorizes material shutdowns, residual-risk decisions and external communications with appropriate advice. Assess notification duties case by case under contract and law. Do not wait for a complete investigation when earlier notice is required.

Backup and recovery dependencies - targets TBD

Map vendor availability, exports, identity, regions, KMS/key versions, support and fourth-party dependencies into recovery plans. RTO, RPO, backup frequency and retention remain TBD pending BIA/business and contractual review under CD-BDR-001. Vendor advertised targets do not establish CloudDesk recovery capability or an agreed SLA. Validate data consistency, authorized recovery access and tenant boundaries. Replication alone does not prove a backup is recoverable. Reconcile deletion commitments, retained copies and holds, with qualified advice where needed.

Quarterly restores and annual continuity exercises

Perform a representative encrypted restore at least quarterly. Record integrity, authorized key access and the outcome, covering dependencies in proportion to risk. Exercise continuity scenarios at least annually and after material changes. Include vendor outages, inaccessible exports, common-region failures and unavailable responders. An annual continuity tabletop does not replace a representative quarterly encrypted restore. A restore alone does not establish broader continuity readiness. Record limitations and remediation. No completed restore or exercise is asserted.

Fourth parties and concentration exposure

Owners identify material subprocessors and fourth parties, their roles, data/location changes and shared upstream dependencies as far as discoverable. Review available flow-down obligations, change notice/objection processes and evidence access. Record opaque chains as risk. Assess correlated failures across cloud, identity, network, support and geographic dependencies, along with substitution costs and lock-in. Seek proportionate alternatives or compensating safeguards. The Engineering Lead reviews them; the CTO accepts material residual risk. Vendors remain accountable under their agreements. CloudDesk retains its own review and incident responsibilities.

Vendor Risk Management Policy

6. Exit, records, exceptions and adoption

Vendor offboarding and portability

Before critical use, plan exit triggers, alternative providers or manual options, export formats, ownership, migration sequence, dependency validation, costs and contract assistance. Test portability proportionately with authorized minimized or synthetic data. No successful migration is asserted. At termination, expiry or scope reduction, remove access in time for the effective end and according to risk. Revoke vendor accounts, sessions, tokens, OAuth grants and integrations. Transfer ownership and verify completion. Preserve the employee rule to revoke access within 24 hours of termination; it is not a universal vendor waiting period. Urgent compromise requires immediate containment.

Data return, deletion and restricted records

Verify data return, usable exports and agreed deletion evidence. Include subcontractors, retained backups and hold limitations. Record gaps and accountable follow-up rather than declaring deletion from a request alone. Preserve keys needed by retained data or recovery. Restrict proposed inventory, assessments, evidence provenance, contracts, approvals, access reviews, incidents, reassessments, exit checks and exception records, and keep version history. Set retention through approved business, contractual and legal review, subject to holds. The minimum 12-month retention for KMS audit logs only is not a universal vendor-record retention rule. No actual audit artifacts are supplied.

Bounded exceptions and emergency deviations

Before a planned deviation, the owner records the requirement, scope, rationale, risk, compensating safeguards, remediation owner and expiry. The Engineering Lead assesses the request; the CTO approves or rejects it. Exceptions expire within 90 days and are reviewed monthly. Renewal requires fresh assessment and approval. Expired approval cannot authorize use. Emergency deviations require a linked incident and next-business-day CTO review. Do not delay urgent containment. Exceptions cannot erase applicable obligations or silently extend employee termination limits. Encryption and destructive key authority remain unchanged. No active exception is asserted.

Annual review and human adoption gate

The Engineering Lead reviews this policy annually and after material changes or incidents. Before adoption, human reviewers must validate tier criteria, inventory coverage, contract/privacy advice, evidence sufficiency, staffing and substitutes, reporting routes, monitoring proposals, recovery dependencies and feasible exits against all seven related policies. Record conflicts, feedback and CTO approval. Approval_status: not_recorded; review_status: requires_user_review. This proposed policy does not establish that CloudDesk has completed vendor assessments, implemented security controls, or obtained independent certification.